

## SÍNTESIS EJECUTIVA: KIT COMPLETO GQM+PRAGMATIC 6 DOCUMENTOS

### Resumen de Contenidos y Flujo de Implementación

**Versión:** 1.0 | **Fecha:** Enero 2026

**Total Documentos:** 6 archivos .md profesionales

**Total Contenido:** ~220 páginas de guía exhaustiva

**Público:** Ejecutivos, CISOs, Risk Managers, Analistas Ciberseguridad

### **PROPÓSITO GENERAL DEL KIT**

Proporcionar **framework integral y operacional** para evaluación de madurez ciberseguridad-IA en organizaciones españolas, alineado con:

-  Regulaciones: NIS2, EU AI Act, ISO 27001, GDPR, DORA
-  Metodología: GQM (Goal-Question-Metric) + PRAGMATIC (9 criterios)
-  Aplicabilidad: 9 indicadores con trazabilidad objetivos ↔ métricas técnicas
-  Implementación: Roadmap 18 meses, presupuesto (€1.9M), ROI (110%)

### **LOS 6 DOCUMENTOS: DESCRIPCIÓN Y FLUJO**

#### **DOCUMENTO 1: Marco Integrativo GQM+PRAGMATIC**

**Archivo:** marco\_gqm\_pragmatic\_ciberseguridad\_es.md

**Tamaño:** ~40 páginas

**Propósito:** Columna vertebral conceptual

### Contenido:

- Introducción framework GQM jerárquico (4 niveles)
- Categorización objetivos nacionales España (Plan Nacional, NIS2, EU AI Act)
- 9 Indicadores detallados:
  - AI-Threat Detection Coverage (MTTD <24h)
  - Vulnerability Management IA (MTTR <15 días)
  - Deepfake Detection Readiness (94% accuracy)
  - SIEM+AI-Threat Hunting (90% proactive detection)
  - AI-Cybersecurity Awareness Training (<5% click-rate)
  - Compliance Madurez NIS2/EU AI Act (95% cumplimiento)
  - AI Supply Chain Resilience (100% SBOM)
  - AI-Enhanced Incident Response (MTTR <30 min)
- Governance Maturity (CISO—CEO)
- Estructura por indicador:
  - GQM Structure (Goal — 4-5 Questions — 4-5 Metrics)
  - Data sources & collection methods
  - PRAGMATIC validation (9 criterios)

Governance Maturity (CISO—CEO)

Estructura por indicador:

### Quién lo usa:

- CISO: Comprensión framework, alineación estratégica
- Risk Manager: Mapeo objetivos — regulaciones
- Security Strategist: Diseño iniciativas basadas indicadores

### Cuándo lo lee:

- Semana 1: CISO + leadership team alignment
- Semana 2-3: Referencia durante interviews
- Ongoing: Validación conceptual

## 2 DOCUMENTO 2: Matriz Evaluación PRAGMATIC Completa

**Archivo:** matriz\_pragmatic\_completa\_es.md

**Tamaño:** ~35 páginas

**Propósito:** Herramienta de Assessment operacional

### Contenido:

- Definición operacional 9 criterios PRAGMATIC (5-point scale)
- Scoring guidance con evidencia requerida por nivel
- Matriz 9×9 consolidada:
- Filas: 9 indicadores
- Columnas: 9 criterios + avg + recomendación
- 

Scores: Todos indicadores valorados (range 3.1-4.6)

- 
- Análisis detallado por indicador:

- Scorecard visual (barras)
- Fortalezas/debilidades específicas
- 

Acciones recomendadas

- 
- Matriz priorización final:

- Fase 1 (Inmediata): Indicadores 1,2,4,5,8,9
- Fase 2 (Mandated): Indicador 6
- Fase 3 (Secondary): Indicadores 3,7

Scores: Todos indicadores valorados (range 3.1-4.6)

Análisis detallado por indicador:

Acciones recomendadas

Matriz priorización final:

### Quién lo usa:

- Facilitator/Assessor: Cuestionario durante interviews
- Analyst: Scoring & validation
- Finance/Leadership: Priorización (por PRAGMATIC score)

### Cuándo lo usa:

- Semana 1-2: Assessment execution (cuestionario)
- Semana 2-3: Scoring & consolidation
- Semana 4: Quality assurance validation

### 3 DOCUMENTO 3: Mapeo Normativo (Preguntas→Regulaciones)

**Archivo:** mapeo\_normativo\_preguntas\_es.md

**Tamaño:** ~50 páginas

**Propósito:** Validación compliance y trazabilidad regulatoria

#### Contenido:

- Mapeo línea-por-línea cada pregunta QM vs:
  - Normativas españolas (Plan Nacional)
  - Regulaciones EU (NIS2, EU AI Act, GDPR, DSA, DORA)
  - Estándares internacionales (ISO 27001, COBIT, NIST)
  - Para cada pregunta:
    - Requisito técnico específico
    - Plazo de cumplimiento
    - Organismo supervisión
    - Puntuación mínima compliance
    - Referencias artículos/clauses
    - Penalidades si no cumple
  - Matriz consolidada:
    - Indicador | Pregunta | Normativa Primaria | Plazo | Score Mín
    - Ejemplo: "AI-Detection 1.1" | "Coverage %" | "NIS2 Art.17" | "Agosto 2026" | "80%"
  - Sección referencias:
    - Links a documentos normativos (descargables)
    - Frameworks reconocidos internacionales
    - Recomendaciones consultores
- Estándares internacionales (ISO 27001, COBIT, NIST)
- Para cada pregunta:
- Penalidades si no cumple

## Matriz consolidada:

Ejemplo: "AI-Detection 1.1" | "Coverage %" | "NIS2 Art.17" | "Agosto 2026" | "80%"

Sección referencias:

### Quién lo usa:

- Compliance Officer: Validación alineación NIS2/EU AI Act
- Risk Manager: Identificación plazos críticos
- Legal: Análisis implicaciones regulatorias
- CISO: Priorización basada deadline

### Cuándo lo usa:

- Semana 2-3: Análisis compliance post-assessment
- Semana 4: Roadmap planning (priorizar por deadline)
- Ongoing: Reference during implementation

### Aplicación Clave:

Ejemplo: "¿Por qué Indicador 6 (Compliance) es Fase 3?"

Razón: NIS2 assessment deadline AUGUST 2026 (mandated)

Acción: Incluir en Phase 2, no Phase 1, porque Phase 1 es foundation

## DOCUMENTO 4: Plantilla Excel IGM+ROI

**Archivo:** plantilla\_excel\_igm\_roi\_es.md

**Tamaño:** ~25 páginas (instrucciones)

**Propósito:** Cálculos automáticos de madurez y retorno financiero

### Contenido:

**Estructura 5 hojas Excel:**

1. Dashboard (Hoja 1):
2. Visión ejecutiva consolidada
3. 9 indicadores: GQM level, PRAGMATIC avg, Compliance %, Deployment %
4. IGM score calculado automáticamente (fórmula ponderada)
5. ROI Year 1 & payback period
6.  
Estado ( ● ● ● ) + prioridad
7.  
Detalle Indicadores (Hojas 2-10, 1 por indicador):
8. Metadatos (Goal, Status)
9. PRAGMATIC scores (importado de Doc #2)
10. GQM madurez actual (Nivel 0-5)
11. Compliance normativo % vs target
12. Implementación operacional % deployed
13. IGM cálculo paso-a-paso
14.  
Métricas clave (baseline vs target)
15.  
Costs & ROI (Hoja 11):
16. Desglose presupuesto por indicador (CapEx/OpEx)
17. Fórmula IGM:  $(PRAGMATIC \times 0.4 + GQM \times 20 + Compliance\% \times 0.3 + Deploy\% \times 0.1)$
18. 3 Escenarios ROI:  
Conservative: 1 incident prevented → -€1.4M Year 1; payback 48 meses  
Realistic: 2 incidents → +€100K Year 1; payback 11 meses (110% 3-year ROI)  
Optimistic: 3 incidents → +€600K Year 1; payback 9 meses (180% ROI)
19.  
Sensitivity analysis (variables  $\pm 20\%$ )
20.  
Maturity Trajectory (Hoja 12):
21. Proyección quarter-by-quarter 18 meses
22. Gráfico: Portfolio IGM 46 (Q4 2025) → 86 (Q2 2027)
23. Milestones clave por fase

24.

Success criteria end-2026

25.

Raw Data Input (Hoja 13):

26. Tabla para entrada manual datos brutos

27. Métrica | Formula | Current Value | Data Source | Last Update

28. Alimentada desde SIEM, ticketing, surveys, etc.

Estado (    ) + prioridad

**Detalle Indicadores (Hojas 2-10, 1 por indicador):**

Métricas clave (baseline vs target)

**Costs & ROI (Hoja 11):**

- Conservative: 1 incident prevented → -€1.4M Year 1; payback 48 meses
- Realistic: 2 incidents → +€100K Year 1; payback 11 meses (110% 3-year ROI)
- Optimistic: 3 incidents → +€600K Year 1; payback 9 meses (180% ROI)

Sensitivity analysis (variables ±20%)

**Maturity Trajectory (Hoja 12):**

Success criteria end-2026

**Raw Data Input (Hoja 13):**

**Fórmulas Clave:**

IGM = (C7\*0.4)+(B7\*20)+(D7\*0.3)+(E7\*0.1) // Ponderado  
ROI% = (SUM(Benefits) - 1900000) / 1900000 // Year 1  
Payback = 12 / ((Annual\_Benefit/12) / 1900000) // Meses

**Quién lo usa:**

- Finance/CFO: Presupuesto validation, ROI justification
- CISO: Tracking progress monthly
- Board: Decision-making (risk appetite vs investment)
- Analyst: Data aggregation & calculations

**Cuándo lo usa:**

- Semana 3 (Post-assessment): Alimentar datos brutos
- Semana 4: Cálculos automáticos → reportable
- Monthly (Ongoing): Re-baselining & trajectory tracking

## 5 DOCUMENTO 5: Plantilla PowerPoint Reporte Ejecutivo

**Archivo:** plantilla\_powerpoint\_reporte\_es.md

**Tamaño:** ~30 páginas (plantilla + notas)

**Propósito:** Presentación Board & C-level (45 minutos)

### Contenido:

#### 12 Diapositivas Clave:

29. Portada: Contexto, fecha, presentador
30. Agenda: Timeline presentación (45 min total)
31. Executive Summary - IGM Snapshot: Current 46/100 vs target 75; vs industry
32. Detailed Maturity (9 Indicadores): Heat map, traffic lights, scores
33. Top 3 Strengths: Governance, IR, Training (celebrar wins)
34. Top 3 Critical Gaps: Vuln.Mgmt, Supply Chain, Deepfake (transparencia)
35. Regulatory Compliance Heatmap: NIS2 (73%), EU AI Act (40%), ISO (71%)
36. Implementation Roadmap (6 Fases): Gantt chart, presupuesto, timeline
37. Budget Breakdown: CapEx/OpEx, desglose por indicador, pie chart
38. Risk Implications (Do Nothing vs Invest): Two-column comparison, financial impact
39. Board Decisions Required: 5 decisiones con recomendaciones (APPROVE/PENDING/REJECT)
40. Next Steps & Q&A: 30-60-90 day roadmap, success metrics

### Visualizaciones:

- IGM gauge (0-100 scale)
- Horizontal bar charts (comparison vs benchmark)
- Heat maps (compliance)
- Gantt charts (timeline)
- Waterfall charts (investment → benefits)
- Tornado charts (sensitivity analysis)
- Traffic light indicators (status)

### Story Arc:

Hook (2 min): "NIS2 deadline August 2026; 6 months; €50M+ penalty if not ready"

Context (5 min): "We're at 46/100 (Level 2); +20% vs industry avg but -20pp vs peers"

Analysis (8 min): "What's working (governance), what's broken (vuln.mgmt, supply chain)"

Solution (10 min): "6-phase roadmap; €1.9M investment; 11-month payback"

Action (5 min): "5 board decisions needed; approval required this week"

Q&A (12 min): Responder preguntas

Total: 42 min (leaving 3 min buffer)



### *Quién lo usa:*

- CISO: Presentador principal
- CFO: Financial slides (budget, ROI)
- Board/CEO: Audiencia; toman decisiones
- Executive Comms: Adaptation para distribución

### *Cuándo se presenta:*

- Semana 4 (post-assessment): Presenta a Board/C-level
- Semana 5: Board meeting & approval
- Monthly (Ongoing): Updates (version adaptada para steering committee)

## **6 DOCUMENTO 6: README Kit Encuesta**

**Archivo:** readme\_kit\_encuesta\_es.md

**Tamaño:** ~20 páginas

**Propósito:** Quick-start guide, FAQ, troubleshooting

### Contenido:

- ¿Qué contiene kit? Tabla 6 documentos + propósito
- Quick Start (5 pasos):
- Download (5 min)
- Preparación (30 min)
- Assessment (3-5 weeks)
- Presentation (1-2 weeks)
- 
- Implementation (6-18 months)
- 
- Cómo usar cada documento (sección 30 min):
- 
- Cuándo usarlo
- Cómo usarlo paso-a-paso
- 
- Preguntas típicas & respuestas
- 
- FAQ (15 preguntas comunes):
- "¿Cuánto tiempo toma assessment?" → 3-5 weeks
- "¿Necesitamos consultant externo?" → Recomendación híbrida (€12K)
- "¿Qué si scores muy bajos?" → Normal; oportunidad
- "¿Todos 9 indicadores simultáneamente?" → No; fases
- "¿Cuál ROI más probable?" → Realistic: 11 meses, 110% 3-year
- "¿Integración ISO 27001?" → Complementario; GQM es macro
- "¿Después assessment?" → 18-month roadmap
- 
- Y más...
- 
- Troubleshooting (5 problemas comunes):
- Stakeholder divergencia scores
- Excel formulas no calculan
- Presupuesto rechazado por Finance
- 
- NIS2 deadline muy cerca (6 meses)

- Referencias: Links documentos normativos, herramientas, consultores
- Checklist: 10 items antes de empezar
- Próximos pasos: Timeline semana-a-semana

Implementation (6-18 months)

**Cómo usar cada documento** (sección 30 min):

Preguntas típicas & respuestas

**FAQ (15 preguntas comunes):**

Y más...

**Troubleshooting (5 problemas comunes):**

NIS2 deadline muy cerca (6 meses)

**Referencias:** Links documentos normativos, herramientas, consultores

**Quién lo usa:**

- Everyone: Primera lectura (15 min de familiarización)
- Project Manager: Ejecutar 5 pasos, timeline, checklist
- Finance/Leadership: FAQ (presupuesto, timeline, ROI)
- Troubleshooters: FAQ + Troubleshooting sections

**Cuándo lo usa:**

- Día 0: Todos leen Introducción (15 min)
- Semana 1: Seguir Quick Start steps
- Weekly: Consultar cuando surge pregunta/problema

## FLUJO DE IMPLEMENTACIÓN INTEGRADO

### SEMANA 1: Introducción & Preparación

- Day 0: README (15 min) → Todos familiarizados
- Day 1: Marco GQM+PRAGMATIC (1 hora) → CISO + leadership alignment
- Day 2-3: Stakeholder kickoff meeting → Explicar assessment
- Day 4-5: Entrevistas (60 min c/u) → 5 stakeholders clave
- Usar: Matriz PRAGMATIC como cuestionario

### SEMANA 2-3: Análisis & Consolidation

- Agregar respuestas en Excel template (Doc #4)
- Validar divergencias vs realidad operacional (SIEM, tickets)
- Mapear findings contra normativas (Doc #3)
- Calcular IGM, ROI escenarios
- Usar: Excel (cálculos automáticos), Mapeo Normativo (validación)

### SEMANA 4: Reporte & Presentación

- Generar PowerPoint usando template (Doc #5)
- Customizar con tu data (9 indicadores, roadmap, presupuesto)
- Rehearsal interno (30 min)
- Presentación Board (45 min)
- Colectar 5 decisiones (firmas de aprobación)
- Usar: PowerPoint template, Excel data

### SEMANA 5+: Roadmap & Ejecución (18 meses)

- Phase 1 (1 mes): Governance foundation (€0)
- Phase 2 (2-3 mes): 5 indicadores críticos (€1.2M)
- Phase 3-5 (6+ mes): Compliance + advanced (€700K)
- Monthly: Re-baseline IGM en Excel
- Quarterly: Board updates (PowerPoint versión adaptada)
- Usar: Todos documentos (seguimiento continuo)

## PRESUPUESTO INTEGRADO

| Fase           | Documentos Usados | Inversión                   | Timeline   | IGM Target |
|----------------|-------------------|-----------------------------|------------|------------|
| 0 - Assessment | 1,2,3,5,6         | €12K (consultant, opcional) | 5 weeks    | N/A → 46   |
| 1 - Foundation | 1,3,4,6           | €0 (internal)               | 1 month    | 46 → 50    |
| 2 - Critical   | 1,3,4,5           | €1.2M                       | 2-3 months | 50 → 65    |
| 3 - Compliance | 1,3,4             | €150K                       | 1-2 months | 65 → 72    |
| 4-6 - Advanced | 1,3,4             | €1.05M                      | 9+ months  | 72 → 85+   |
| TOTAL 2026     | All 6             | €2.4M                       | 18 months  | 46 → 85    |

**Note:** €1.9M de \$4 earlier documents; €0.5M additional for full optimization by end 2026

## INDICADORES CLAVE INTEGRADOS

| Métrica        | Current | Target 2026      | Target 2027    | Documento |
|----------------|---------|------------------|----------------|-----------|
| Portfolio IGM  | 46      | 76 (L4)          | 85 (L4+)       | Doc 4,5   |
| MTTD           | 50 días | <24 horas        | <12 horas      | Doc 1,2,4 |
| Vuln MTTR      | 22 días | <15 días         | <5 días        | Doc 1,2,4 |
| Click-rate     | 28%     | <5%              | <2%            | Doc 1,2,4 |
| NIS2 Readiness | 73%     | 95%+             | 98%+           | Doc 3,4   |
| EU AI Act      | 40%     | 85%+             | 95%+           | Doc 3,4   |
| Compliance Avg | 68%     | 88%+             | 93%+           | Doc 3,4   |
| ROI Year 1     | N/A     | 110% (realistic) | 200%+ (3-year) | Doc 4,5   |

## ✓ CHECKLIST INTEGRACIÓN 6 DOCUMENTOS

### Pre-Assessment:

- [ ] Download & review todos 6 documentos (2 horas)
- [ ] Designar project lead (CISO)
- [ ] Asignar stakeholders (5 clave)
- [ ] Preparar facilitator externo (opcional)
- [ ] Schedule interviews Week 1

### During Assessment:

- [ ] Usar Doc #2 (Matriz) como cuestionario
- [ ] Referencia Doc #1 (Marco) para contexto
- [ ] Consulta Doc #3 (Mapeo) para regulaciones

### Post-Assessment:

- [ ] Alimentar Doc #4 (Excel) con datos brutos
- [ ] Validar contra Doc #3 (Mapeo Normativo)
- [ ] Customizar Doc #5 (PowerPoint)
- [ ] Seguir Doc #6 (README) para timeline

### Presentation & Beyond:

- [ ] Presentar Doc #5 (PowerPoint) a Board
- [ ] Colectar aprobaciones
- [ ] Iniciar roadmap usando Doc #1 (phasing)
- [ ] Monthly tracking con Doc #4 (Excel)
- [ ] Referencia continua Doc #6 (README) para Q&A

## 🎯 CONCLUSIÓN: KIT COMO SISTEMA INTEGRADO

Los 6 documentos funcionan **como sistema cohesivo**, no como piezas independientes:

41. Doc #1: Arquitectura conceptual (framework)
42. Doc #2: Herramienta operacional (assessment)
43. Doc #3: Validación regulatoria (compliance check)
44. Doc #4: Financiero & tracking (ROI, trending)
45. Doc #5: Comunicación ejecutiva (board presentation)
46. Doc #6: Guía práctica & soporte (how-to, FAQ)

**Flujo típico:** Marco (conceptual) → Matriz (assessment) → Mapeo (validation) → Excel (financiero) → PowerPoint (presentación) → README (execution)

**Valor Total:**

- Metodología rigurosa (GQM+PRAGMATIC)
- Cobertura regulatoria completa (NIS2, EU AI Act, ISO, GDPR)
- Operacionalización clara (9 indicadores, 18-month roadmap)
- Business case cuantificado (€1.9M investment, 110% ROI, 11-month payback)
- Presentación ejecutiva convincente (board-ready)

**FIN DE SÍNTESIS EJECUTIVA**

*Kit Completo: 6 documentos profesionales | ~220 páginas | Listo para implementación*